

Hobbeast — Üzleti kérés összefoglaló

Verzió: 1.62.0 Dátum: 2026-09-05

A biztonsági audit vak volt — most már lát, és 20 függvényt bezártunk az anon elől

Az előző release közben derült ki, hogy a scripts/audit-security-definer.mjs csak a /²⁰²⁶⁰⁸(?:22|25|26)/ mintájú migrációkat vizsgálja. ****2026-08-26 óta egyetlen migráció sem volt auditálva**** — a kimenet négy új migráción át változatlanul „300 definíció / 81 migráció” volt. Ha egy audit száma release-eken át nem mozdul, az nem stabilitás, hanem gyanús.

Kiszélesítve: 368 definíció / 168 migráció, és azonnal előjött ****24 SECURITY DEFINER függvény explicit REVOKE nélkül**** — köztük a teljes jegyértékesítés, a szervezeti API-kulcs-kezelés és a multi-brand RPC-k.

****A mélyebb baj viszont az, hogy a REVOKE ... FROM PUBLIC ebben a projektben önmagában semmit nem csinál.**** Két default működik egyszerre: a Postgres a PUBLIC-nak ad EXECUTE-ot, a Supabase default privileged pedig ****közvetlenül az anon és authenticated szerepek is****. Élesben lemérve: PUBLIC-only revoke után az ACL továbbra is {postgres=X/postgres, anon=X/postgres, ...}. A repóban 214 revoke nevezi meg az anont, 152 csak a PUBLIC-ot — azok hatástalanok.

Amit ez a release csinál: A 24 függvény lezárva (20260905210000), mindegyiknél FROM PUBLIC, anon, authenticated revoke, majd pontosan visszaadott jogosultság. Az élesben anonként hívható SECURITY DEFINER függvények száma 159 → 139. Amit szándékosan nyitva hagytunk, és miért: a has_role és az is_organization_member RLS-policykben fut, tehát kötelező nekik az anon EXECUTE — nélküle minden rájuk hivatkozó policy elhasal. A list_ticket_types_public marad anon, mert egy kijelentkezett látogató is látja a jegytípusokat. A trigger-függvények teljesen elzárva. Előtte lemértem (és visszagörgettem): a trigger EXECUTE nélkül is lefut, mert a Postgres a jogot a trigger *létrehozásakor* ellenőrzi, nem tüzeléskor. Az audit ratchet-et kapott. Minden migrációt néz, és a cutoff (20260905) utániaknál megköveteli, hogy a revoke megnevezze az anont. A 152 régi PUBLIC-only revoke érintetlen: append-only migrációt nem írunk át, és mindegyik külön döntést kíván. A szabály működését eldobható migrációval ellenőriztem — kiváltotta a hibát, majd töröltem.

Viselkedésváltozás a kliensnek: az anon nem hívhatja többé közvetlenül a jegy-, szervezet- és API-kulcs-RPC-eket. A listTicketTypesAdmin burkolója minden hibát null-ra fordít, és pont abból derül ki, hogy valaki nem operátor — így egy kijelentkezett látogató ugyanazt az eredményt kapja, csak más úton. 15 jogosultság-ellenőrzés élesben, mind a szándék szerint.

Nyitott adósság, tudatosan: 347 SECURITY DEFINER függvényből ****139 továbbra is anon-hívható****. A többségüket belső capability-ellenőrzés védi, de a felület nagy. Ezt forrásonkénti elemzéssel kell csökkenteni, nem tömeges revoke-kal — rögzítve a .governance/codingLessonsLearnt.md-ben.

Dokumentáció

scraper-worker/README.md: új collection frontier fejezet — az állapotdiagram, a prioritás-szabály, a Crawl-delay/backoff viselkedés, a kill switch és az, hogy a planner miért injektált.
.governance/codingLessonsLearnt.md: a Supabase-jogosultsági csapda, az audit vak ablaka, és a trigger-elzárás mérése.

Ez az összefoglaló 2026-09-05-én készült visszamenőleg, a CHANGELOG.md megfelelő bejegyzéséből származtatva, mert ehhez a verzióhoz eredetileg nem készült versioning-artefaktum. A tartalma a changeloból ellenőrizhető; nem a kiadás napján kelt dokumentum.